

Checklist

Create a Security Program

1. Establish the Asset Management Program

- ☐ Define the scope and objectives of the asset management program.
- ☐ Treat asset management as an ongoing security process, not a one-time inventory exercise.
- ☐ Identify all asset categories that must be tracked.
- ☐ Assign an owner or custodian to every asset or asset group.
- ☐ Establish roles and responsibilities for maintaining asset information.
- ☐ Define a consistent naming convention for assets.
- ☐ Document the asset management process and procedures.
- ☐ Identify an executive sponsor or champion for the program.
- ☐ Form a cross-functional asset management team that includes relevant departments.

2. Establish a Single Source of Truth

- ☐ Select one authoritative system for asset records.
- ☐ Ensure teams know which system is the official source of asset information.
- ☐ Integrate existing data sources where practical.
- ☐ Establish processes to prevent duplicate or conflicting asset records.
- ☐ Define who may create, modify, and delete asset records.
- ☐ Back up asset inventory data.
- ☐ Maintain version history or change records where possible.
- ☐ Review the inventory regularly for accuracy and completeness.

3. Select an Appropriate Asset Repository

- ☐ Choose a storage solution appropriate for the organization's size and complexity.

- ☐ For small environments, determine whether a spreadsheet or simple database is sufficient.
- ☐ For growing environments, evaluate dedicated asset management platforms.
- ☐ For large environments, evaluate enterprise-grade or customized asset management solutions.
- ☐ Ensure the system supports required security controls.
- ☐ Ensure the system is scalable.
- ☐ Ensure the system supports reporting.
- ☐ Ensure the system can integrate with other business and security systems.
- ☐ Plan to migrate away from basic tools before they become difficult to maintain.

4. Create an Inventory Schema

For every applicable asset, record:

- ☐ Unique asset ID
- ☐ Asset name
- ☐ Asset type/category
- ☐ Description or purpose
- ☐ Manufacturer/vendor
- ☐ Model
- ☐ Serial number
- ☐ Purchase or acquisition date
- ☐ Warranty/support expiration
- ☐ Physical or logical location
- ☐ Assigned user or department
- ☐ Asset owner
- ☐ Asset custodian
- ☐ Business function supported
- ☐ Criticality rating
- ☐ Risk rating
- ☐ Data classification
- ☐ Lifecycle status
- ☐ Configuration information
- ☐ Software/firmware/OS version
- ☐ Licensing information
- ☐ Support contact information
- ☐ Relevant dependencies and integrations
- ☐ Backup location or recovery information

- ☐ Last inventory verification date

5. Classify Data

- ☐ Define a simple, documented data classification scheme.
- ☐ Include classifications such as Public, Internal, Confidential, and Highly Confidential/Sensitive as appropriate.
- ☐ Identify the types of data each department creates, processes, stores, and transmits.
- ☐ Identify personally identifiable information (PII).
- ☐ Identify financial information.
- ☐ Identify employee and HR information.
- ☐ Identify authentication credentials and secrets.
- ☐ Identify regulated information such as PHI or payment card data where applicable.
- ☐ Identify intellectual property and trade secrets.
- ☐ Assign a classification to relevant systems, applications, and data stores.
- ☐ Document handling requirements for each classification.
- ☐ Define appropriate access controls for each classification.
- ☐ Define encryption requirements where appropriate.
- ☐ Define approved methods for sharing sensitive information.
- ☐ Define retention and disposal requirements.
- ☐ Train staff on the classification scheme.
- ☐ Review classifications periodically.

6. Interview Business and Data Owners

Ask each department:

- ☐ What types of data do you handle, process, or store?
- ☐ What sensitive or confidential information do you regularly use?
- ☐ What regulatory or industry requirements apply?
- ☐ What audit requirements or findings exist?
- ☐ Where is the data stored?
- ☐ How is the data accessed?
- ☐ What security controls currently protect it?
- ☐ Who is responsible for the data?
- ☐ Have there been previous breaches, leaks, or security incidents?

- ☐ What retention requirements apply?
- ☐ How long is the data stored?
- ☐ How is data shared internally?
- ☐ How is data shared with external parties?
- ☐ What protocols are used to transfer sensitive information?
- ☐ What classification or labeling practices already exist?
- ☐ What risks or challenges does the department see?

7. Assign Asset Criticality

For each significant asset:

- ☐ Determine the business impact if the asset becomes unavailable.
- ☐ Determine the impact if the asset is compromised.
- ☐ Determine whether the asset supports a critical business process.
- ☐ Identify legal or regulatory requirements associated with the asset.
- ☐ Determine the cost of replacement or recovery.
- ☐ Assign a documented criticality rating.
- ☐ Review criticality when the asset's purpose or business importance changes.

8. Assign Asset Risk

- ☐ Identify threats that could affect each important asset.
- ☐ Identify relevant vulnerabilities.
- ☐ Estimate the likelihood of a security event.
- ☐ Estimate the potential business impact.
- ☐ Consider historical incidents and industry data where available.
- ☐ Assign a documented risk level.
- ☐ Prioritize high-risk and high-criticality assets for protection.
- ☐ Review risk ratings after significant changes or incidents.

9. Connect Inventory Data to Security Operations

Use criticality and risk information to prioritize:

- ☐ Patch management
- ☐ Vulnerability remediation
- ☐ Security monitoring

- ☐ Data labeling
- ☐ Incident response
- ☐ Backup and recovery
- ☐ Access reviews
- ☐ Security testing
- ☐ Replacement and lifecycle decisions

10. Inventory Network Equipment

For routers, switches, firewalls, wireless equipment, and similar devices, track:

- ☐ Hostname
- ☐ Device type
- ☐ Manufacturer/model
- ☐ Serial number
- ☐ Licensing information
- ☐ Physical location
- ☐ Management IP address
- ☐ Production IP addresses
- ☐ Software/firmware version
- ☐ Configuration backup location
- ☐ Warranty/support information
- ☐ System owner
- ☐ Criticality
- ☐ Risk rating

11. Document Network Information

- ☐ Maintain current network diagrams.
- ☐ Document DHCP servers.
- ☐ Document DNS servers.
- ☐ Record network ranges and subnets.
- ☐ Record internet ingress and egress points.
- ☐ Record public-facing IP addresses.
- ☐ Record default gateways.
- ☐ Maintain ISP information and support contacts.
- ☐ Establish normal network performance baselines.
- ☐ Review network documentation after major changes.

12. Inventory Servers

For each physical or virtual server, track:

- ☐ Hostname
- ☐ IP address(es)
- ☐ Operating system and version
- ☐ Applications and roles
- ☐ Virtualization platform
- ☐ Hardware specifications
- ☐ Storage configuration
- ☐ Department or team responsible
- ☐ System owner
- ☐ Remote-access status
- ☐ Open ports/services
- ☐ Management interface information
- ☐ Backup configuration
- ☐ Compliance requirements
- ☐ Sensitive data stored or processed
- ☐ Performance baseline
- ☐ Warranty/support information
- ☐ Patch level
- ☐ Criticality
- ☐ Risk rating

13. Inventory Desktops and Endpoints

For each endpoint, track:

- ☐ Hostname
- ☐ Make/model
- ☐ Serial number
- ☐ Hardware specifications
- ☐ Asset tag
- ☐ Assigned user
- ☐ Department
- ☐ Location
- ☐ Operating system
- ☐ Patch level

- ☐ Installed software
- ☐ Encryption status
- ☐ Endpoint security status
- ☐ Warranty information
- ☐ Criticality
- ☐ Risk rating

14. Inventory Users and Accounts

- ☐ Record user's name and job role.
- ☐ Record department.
- ☐ Record appropriate contact information.
- ☐ Track account creation date.
- ☐ Track account termination/deactivation date.
- ☐ Record MFA status.
- ☐ Record access rights and permissions.
- ☐ Identify database administrator accounts.
- ☐ Identify domain/enterprise administrator accounts.
- ☐ Identify root/local administrator accounts.
- ☐ Identify service accounts.
- ☐ Identify privileged or shared accounts.
- ☐ Assign an owner to service accounts.
- ☐ Conduct periodic access reviews.
- ☐ Remove access promptly when users leave or change roles.

15. Inventory Applications

For each application, track:

- ☐ Application name
- ☐ Version
- ☐ Application owner
- ☐ Business purpose
- ☐ Administrative users
- ☐ Authorized users/groups
- ☐ Vendor
- ☐ Vendor support contact
- ☐ Licensing information

- ☐ Renewal date
- ☐ Dependencies
- ☐ Integration points
- ☐ Servers or platforms used
- ☐ Third parties involved
- ☐ Authentication method
- ☐ Data classification
- ☐ Data created by the application
- ☐ Data processed by the application
- ☐ Data stored by the application
- ☐ Data transmission methods
- ☐ APIs or file-transfer mechanisms
- ☐ Data retention requirements
- ☐ Deletion schedule
- ☐ Criticality
- ☐ Risk rating

16. Inventory Cloud Assets

Monitoring and Logging

- ☐ Document monitoring services.
- ☐ Document alerting configuration.
- ☐ Record where alerts are sent.
- ☐ Record what conditions are monitored.
- ☐ Document log-storage locations.
- ☐ Document log-retention periods.
- ☐ Document integrations with third-party monitoring tools.

Users and Secrets

- ☐ Document the cloud secret-management solution.
- ☐ Identify privileged cloud users.
- ☐ Record roles and security policies.
- ☐ Identify accounts assigned to each role.
- ☐ Review permissions periodically.

Network Infrastructure

- ☐ Inventory VPCs or equivalent virtual networks.
- ☐ Document subnets and CIDR ranges.
- ☐ Document network security groups.
- ☐ Document firewall/security-group rules.
- ☐ Identify public-facing cloud resources.

Databases

- ☐ Inventory database instances.
- ☐ Document encryption settings.
- ☐ Document backup configuration.
- ☐ Document retention policies.
- ☐ Assign a data classification.
- ☐ Record owners and administrators.

Compute and Storage

- ☐ Inventory virtual machines.
- ☐ Inventory containers where applicable.
- ☐ Inventory cloud storage buckets/blobs.
- ☐ Inventory application/platform instances.
- ☐ Identify internet-exposed resources.
- ☐ Tag resources with owner, risk, criticality, environment, and purpose.

Cloud Policies

- ☐ Inventory IAM policies.
- ☐ Inventory access-control policies.
- ☐ Review policies for excessive permissions.
- ☐ Remove unused cloud resources and permissions.

17. Track Certificates and Domains

- ☐ Inventory domains.
- ☐ Inventory subdomains where feasible.
- ☐ Record domain owners.
- ☐ Record domain expiration dates.
- ☐ Inventory TLS/SSL certificates.
- ☐ Record certificate owners.

- ☐ Record certificate expiration dates.
- ☐ Configure expiration alerts.
- ☐ Track renewal status.
- ☐ Remove abandoned DNS records.
- ☐ Review for potential dangling DNS entries or subdomain takeover risk.

18. Define the Asset Lifecycle

Procure

- ☐ Create the asset record when the asset is acquired.
- ☐ Record serial number or unique identifier.
- ☐ Record purchase order information where applicable.
- ☐ Record asset owner.
- ☐ Assign criticality.
- ☐ Record manufacturer and model.
- ☐ Record warranty/support information.

Deploy

- ☐ Update the asset's location.
- ☐ Record assigned user or department.
- ☐ Replace default credentials before deployment.
- ☐ Apply required security configuration.
- ☐ Apply current patches and updates.
- ☐ Install endpoint/security software.
- ☐ Scan for vulnerabilities before production use where appropriate.
- ☐ Verify encryption requirements.
- ☐ Confirm the asset record is complete.

Manage

- ☐ Track location changes.
- ☐ Track user or owner changes.
- ☐ Track department changes.
- ☐ Track hardware upgrades.
- ☐ Track software upgrades.
- ☐ Track repairs.
- ☐ Track storage or inactive status.

- ☐ Track configuration changes.
- ☐ Track warranty and support status.
- ☐ Reassess criticality and risk when necessary.

Decommission

- ☐ Mark the asset as pending decommission.
- ☐ Identify the classification of data stored on it.
- ☐ Back up required business records.
- ☐ Revoke accounts, tokens, certificates, and access.
- ☐ Remove the asset from monitoring systems.
- ☐ Remove DNS, DHCP, cloud, and management records as appropriate.
- ☐ Remove licenses or transfer them to another asset.
- ☐ Select an approved data-destruction method.
- ☐ Verify successful sanitization or destruction.
- ☐ Record the disposal method and date.
- ☐ Retain destruction documentation when required.
- ☐ Mark the asset as retired/disposed in the inventory.

19. Securely Dispose of Storage Devices

For SSDs and other storage media:

- ☐ Determine the sensitivity of the data before disposal.
- ☐ Use approved secure-erase functionality when appropriate.
- ☐ Use cryptographic erasure when full-disk encryption has been properly implemented.
- ☐ Physically destroy media when required by sensitivity or policy.
- ☐ Use an approved destruction vendor where applicable.
- ☐ Maintain certificates of destruction when required.
- ☐ Document the disposal decision and completion.

20. Gather Asset Information

- ☐ Use automated discovery wherever practical.
- ☐ Review ARP data where useful.
- ☐ Review DHCP records.
- ☐ Use network discovery/scanning tools.
- ☐ Use SNMP information where appropriate.

- ☐ Use operating-system management interfaces.
- ☐ Integrate vulnerability scanner results.
- ☐ Integrate endpoint management data.
- ☐ Integrate IAM information.
- ☐ Integrate cloud-provider inventory data.
- ☐ Reconcile automated discoveries with the official inventory.
- ☐ Investigate unmanaged or unknown assets.

21. Integrate Vulnerability Management

- ☐ Import vulnerability information into asset records or link the systems.
- ☐ Associate vulnerabilities with affected assets.
- ☐ Record software and operating-system versions.
- ☐ Use asset criticality to prioritize remediation.
- ☐ Use risk ratings to prioritize remediation.
- ☐ Track remediation status.
- ☐ Identify unsupported or end-of-life software.
- ☐ Regularly scan for newly introduced assets.

22. Track Installed Software

- ☐ Inventory software installed on endpoints and servers.
- ☐ Record software name and version.
- ☐ Record publisher/vendor.
- ☐ Record install location where useful.
- ☐ Identify unauthorized software.
- ☐ Identify outdated software.
- ☐ Identify vulnerable software.
- ☐ Identify unused software.
- ☐ Identify users of licensed applications.
- ☐ Compare installed software against license entitlements.

23. Manage Software Licensing

- ☐ Maintain records of purchased licenses.
- ☐ Maintain records of deployed licenses.
- ☐ Track license keys securely.
- ☐ Record vendor contacts.

- ☐ Track renewal dates.
- ☐ Track subscription expiration dates.
- ☐ Remove or recover licenses when employees leave.
- ☐ Reassign licenses when devices are repurposed.
- ☐ Reconcile entitlements against actual installations.
- ☐ Prepare for vendor software audits.

24. Use Cloud-Native Inventory Capabilities

- ☐ Enable configuration/inventory services provided by the cloud provider.
- ☐ Inventory cloud resources automatically.
- ☐ Track configuration changes.
- ☐ Apply consistent resource tags.
- ☐ Identify newly created resources.
- ☐ Identify unapproved resources.
- ☐ Detect insecure configurations.
- ☐ Identify resources created from outdated or vulnerable images.
- ☐ Alert responsible teams when risky changes occur.
- ☐ Reconcile cloud inventory with the enterprise source of truth.

25. Manage Infrastructure as Code

- ☐ Track infrastructure defined through tools such as Terraform or equivalent platforms.
- ☐ Maintain infrastructure code in version control.
- ☐ Require review and approval for infrastructure changes.
- ☐ Maintain an audit trail of changes.
- ☐ Use infrastructure state information to support asset inventory.
- ☐ Compare deployed infrastructure against approved code.
- ☐ Investigate unmanaged infrastructure created outside approved processes.

26. Implement Change Tracking

- ☐ Record asset additions.
- ☐ Record asset removals.
- ☐ Record configuration changes.
- ☐ Record software installations.
- ☐ Record software removals.

- ☐ Record software version changes.
- ☐ Record ownership changes.
- ☐ Record user-assignment changes.
- ☐ Record location changes.
- ☐ Record risk/criticality changes.
- ☐ Alert on unauthorized or unexpected changes.
- ☐ Maintain sufficient history to support investigations.

27. Monitor and Report

- ☐ Alert on software-license renewals.
- ☐ Alert on warranty expirations.
- ☐ Alert on certificate expirations.
- ☐ Alert on domain expirations.
- ☐ Alert on unsupported software.
- ☐ Alert on unpatched critical systems.
- ☐ Alert on unauthorized software.
- ☐ Alert on new or unknown devices.
- ☐ Alert on missing endpoint protection.
- ☐ Alert on disabled encryption where required.
- ☐ Generate regular asset inventory reports.
- ☐ Report trends to management.
- ☐ Use inventory trends to support budgeting and procurement.
- ☐ Track inventory completeness and accuracy as measurable metrics.

28. Automate Wherever Possible

- ☐ Identify repetitive asset-management tasks.
- ☐ Automate asset discovery.
- ☐ Automate data collection from authoritative sources.
- ☐ Automate synchronization with DNS and DHCP.
- ☐ Automate vulnerability-to-asset correlation.
- ☐ Automate software inventory.
- ☐ Automate cloud inventory.
- ☐ Automate warranty/license/certificate expiration alerts.
- ☐ Automate stale-account detection.
- ☐ Automate reporting.
- ☐ Validate automated data before treating it as authoritative.

29. Control Unmanaged Assets

- ☐ Establish a process for reporting newly discovered assets.
- ☐ Investigate devices not found in the official inventory.
- ☐ Determine the owner of undocumented assets.
- ☐ Determine why the asset bypassed the normal process.
- ☐ Add legitimate assets to inventory.
- ☐ Isolate or remove unauthorized assets where appropriate.
- ☐ Correct the process that allowed the asset to remain undocumented.

30. Maintain Documentation Quality

- ☐ Keep documentation current.
- ☐ Use standardized terminology.
- ☐ Use consistent naming conventions.
- ☐ Record owners for documents and inventories.
- ☐ Record revision dates.
- ☐ Review documentation after significant changes.
- ☐ Ensure documentation is accessible to authorized personnel.
- ☐ Protect sensitive documentation from unauthorized access.
- ☐ Record lessons learned from incidents and operational problems.
- ☐ Update procedures when weaknesses are identified.

31. Periodic Asset Management Review

Monthly or Frequently

- ☐ Review newly discovered assets.
- ☐ Review high-risk vulnerabilities on critical assets.
- ☐ Review unauthorized software.
- ☐ Review approaching expirations.
- ☐ Review failed inventory integrations.
- ☐ Review assets with missing owners.

Quarterly

- ☐ Reconcile major asset sources against the central inventory.
- ☐ Review privileged accounts.

- ☐ Review cloud resources.
- ☐ Review asset risk and criticality.
- ☐ Review unsupported software and operating systems.
- ☐ Review license utilization.
- ☐ Review stale or inactive assets.

Annually

- ☐ Conduct a complete asset inventory review.
- ☐ Review the asset-management policy.
- ☐ Review the data-classification scheme.
- ☐ Review lifecycle procedures.
- ☐ Review disposal procedures.
- ☐ Review naming and tagging standards.
- ☐ Review integrations and automation.
- ☐ Review vendor and support information.
- ☐ Review the effectiveness of the single source of truth.
- ☐ Identify and prioritize improvements for the next year.

32. Final Program Validation

- ☐ Can you quickly determine who owns every critical asset?
- ☐ Can you identify all internet-facing systems?
- ☐ Can you identify which assets contain sensitive data?
- ☐ Can you identify which systems have a vulnerable software version?
- ☐ Can you identify which users have privileged access?
- ☐ Can you locate a lost or stolen employee device in the inventory?
- ☐ Can you determine which assets are affected by a new vulnerability?
- ☐ Can you identify unauthorized cloud spending or resources?
- ☐ Can you identify systems associated with a security incident?
- ☐ Can you determine how sensitive data flows between systems?
- ☐ Can you identify expired or soon-to-expire licenses, certificates, warranties, and domains?
- ☐ Can you verify that retired assets were securely sanitized?
- ☐ Can you produce an accurate inventory report when management or auditors request one?
- ☐ Is asset information updated as part of normal business operations?
- ☐ Is the inventory actively used for security decisions rather than simply maintained as documentation?

